

Auditoría y Gestión de Permisos de Archivos en Linux

Rol: Analista de Ciberseguridad Junior • **Marco Técnico:** Control de Accesos y Menor Privilegio (Principio de Least Privilege)

1. Descripción del Proyecto

En el ámbito de la ciberseguridad corporativa, la correcta asignación de privilegios es un pilar fundamental para mitigar riesgos. El equipo de investigación de nuestra organización detectó que las configuraciones de permisos dentro del directorio estratégico de proyectos (projects) no reflejaban de manera estricta los niveles de autorización requeridos.

Dejar accesos abiertos de forma indebida vulnera el **Principio de Menor Privilegio (Least Privilege)**, el cual dicta que un usuario, proceso o sistema debe tener exclusivamente los accesos necesarios para realizar sus tareas y absolutamente nada más. El objetivo de esta práctica técnica consiste en realizar una auditoría completa del directorio, interpretar detalladamente los niveles de acceso actuales y reconfigurar los permisos utilizando comandos nativos de Linux para asegurar los activos de información del equipo de investigación.

2. Fundamentos Básicos: La Cadena de Permisos en Linux

Para quien se adentra por primera vez en sistemas Linux, el comando `ls -la` expone al inicio de cada línea una cadena críptica de 10 caracteres (por ejemplo, `-rw-rw-r--`). Esta cadena es en realidad un mapa de seguridad perfecto y altamente estructurado.



- **1er Carácter (Tipo de activo):** Indica qué es el elemento. Un guion (-) significa que es un archivo regular. Una letra d representa un directorio (una carpeta).
- **2do al 4to Carácter (Usuario / Propietario):** Define las acciones que puede realizar el usuario dueño del archivo (u).
- **5to al 7mo Carácter (Grupo):** Define las acciones permitidas para los usuarios que pertenecen al grupo asignado al archivo (g).
- **8vo al 10mo Carácter (Otros):** Aplica a cualquier otro usuario del sistema operativo que no sea el propietario ni forme parte del grupo (o).

Los Tres Permisos Clave:

Símbolo	Permiso	Significado en Archivos	Significado en Directorios (Carpetas)
r	Lectura (Read)	Permite abrir y ver el contenido del archivo.	Permite listar los archivos que contiene la carpeta (usar <code>ls</code>).
w	Escritura (Write)	Permite modificar, editar o borrar el archivo.	Permite crear, eliminar o renombrar archivos dentro de la carpeta.
x	Ejecución (Execute)	Permite correr el archivo si es un programa o script.	Permite "entrar" a la carpeta (usar <code>cd</code>) para trabajar en ella.

¿Qué significa el guion corto (-)?

Cuando en lugar de una letra encuentras un guion (-) dentro de las tripletas de permisos, significa explícitamente que ese permiso ****no ha sido concedido****. Por ejemplo, `r--` significa acceso de lectura, pero denegada la escritura y la ejecución.

3. Expansión Avanzada: El Sistema Octal (Numérico)

Aunque Linux permite modificar permisos usando letras (Modo Simbólico, ej: `u+w`), los profesionales prefieren el **Modo Octal**. Este sistema asigna un valor matemático binario a cada tipo de permiso, sumándolos para obtener un número de un solo dígito para cada perfil (Usuario, Grupo, Otros).

Lectura (r) = 4

Escritura (w) = 2

Ejecución (x) = 1

Al sumar los valores de una tripleta, obtenemos combinaciones exactas del 0 al 7. Un permiso completo de lectura, escritura y ejecución (`rwX`) equivale a $4+2+1=7$. Un acceso de solo lectura y escritura (`rw-`) equivale a $4+2+0=6$.

Tabla de Modos Octales Comunes de Seguridad:

Código Octal	Representación Simbólica	Nivel de Seguridad	Caso de Uso Común
755	<code>rxwxr-xr-x</code>	Público / Estándar	Directorios web o scripts que cualquiera puede leer/ejecutar, pero solo el dueño modifica.
644	<code>rw-r--r--</code>	Seguro Estándar	Archivos de texto o código fuente que cualquiera lee, pero solo el dueño edita.
600	<code>rw-----</code>	Alta Seguridad	Archivos privados de configuración, claves privadas SSH o credenciales de bases de datos.
700	<code>rxw-----</code>	Restringido Máximo	Directorios privados del usuario raíz (root) o administradores del sistema.

4. Desarrollo del Laboratorio Paso a Paso

Fase 1: Auditoría Inicial del Entorno

El primer paso crítico antes de cualquier cambio es observar el estado actual de los sistemas. Se accedió a la terminal y se ejecutó el comando para listar detalladamente todos los elementos del directorio de investigación.

```
●●● Consola de Auditoría de Sistemas

researcher2@ubuntu:~/projects$ ls -la
total 32
drwxr-xr-x 3 researcher2 research 4096 May 20 18:30 .
drwxr-xr-x 4 root root 4096 May 20 18:25 ..
drwxrwxr-x 2 researcher2 research 4096 May 20 18:30 drafts
-rw-rw-rw- 1 researcher2 research 128 May 20 18:30 .project_x.txt
-rw-rw-rw- 1 researcher2 research 850 May 20 18:30 project_k.txt
-rw-rw-r-- 1 researcher2 research 412 May 20 18:30 project_t.txt
```

Interpretación de la Auditoría:

- El archivo de referencia `project_t.txt` tiene la configuración estándar `-rw-rw-r--` (664 octal): el usuario y el grupo leen y escriben, mientras que terceros solo leen. No posee anomalías de riesgo alto.
- El archivo `project_k.txt` muestra un riesgo severo: permisos `-rw-rw-rw-`. Esto implica que la categoría "Otros" (cualquier cuenta no autorizada en el sistema) tiene capacidad de modificar y sabotear los datos de la investigación.
- El archivo `.project_x.txt` es un **archivo oculto** (identificable porque inicia con un punto). Al igual que el anterior, expone permisos permisivos de escritura a todo el sistema operativo de manera crítica.
- La carpeta `drafts` presenta el indicador de tipo directorio (`d`) con permisos iniciales de ejecución para el grupo, lo cual requiere un ajuste estricto basado en la nueva política.

Fase 2: Remoción de Accesos No Autorizados en Archivos Estándar

La dirección dictaminó que la categoría de "Otros" (other) bajo ninguna circunstancia debe poseer permisos de escritura en los archivos de la corporación. Para subsanar el hallazgo de `project_k.txt`, procedí a restarle los permisos correspondientes.

```
●●● Consola de Modificación

researcher2@ubuntu:~/projects$ chmod o-w project_k.txt
researcher2@ubuntu:~/projects$ ls -la project_k.txt
-rw-rw-r-- 1 researcher2 research 850 May 20 18:30 project_k.txt
```

Explicación Técnica: El argumento simbólico `o-w` le ordena al comando `chmod` sustraer (-) el permiso de escritura (`w`) al perfil de otros usuarios (`o`). Al verificar con `ls -la`, la cadena se actualizó correctamente a `-rW-rW-r--`.

Equivalente Numérico Profesional

Este mismo endurecimiento de seguridad se pudo haber consolidado de manera directa utilizando el código octal: `chmod 664 project_k.txt`.

Fase 3: Gestión de Permisos Críticos en Archivos Ocultos Archivados

El equipo de investigación archivó recientemente el documento confidencial oculto `.project_x.txt`. La nueva directiva estipula que ****nadie**** (ni el propio creador) debe tener permiso de escritura para evitar modificaciones accidentales, debiendo asegurar únicamente el acceso de lectura para el usuario y el grupo de trabajo.

```
Consola de Hardening

researcher2@ubuntu:~/projects$ chmod u-w,g-w,o-w .project_x.txt
researcher2@ubuntu:~/projects$ chmod g+r .project_x.txt
researcher2@ubuntu:~/projects$ ls -la .project_x.txt
-r--r----- 1 researcher2 research 128 May 20 18:30 .project_x.txt
```

Análisis de la Operación Simbólica: Primero, removí secuencialmente la capacidad de escribir al usuario (`u-w`), al grupo (`g-w`) y a otros (`o-w`). Posteriormente, me aseguré de dar el permiso explícito de lectura al grupo (`g+r`). El resultado final es una cadena de protección de alta seguridad: `-r--r-----`.

Optimización Octal Eficiente

Hacer esto de forma simbólica requiere múltiples comandos y es propenso a confusión. En una infraestructura de producción real, un Ingeniero de Ciberseguridad aplica esto de inmediato con un comando único de alta precisión: `chmod 440 .project_x.txt` (4 para el dueño, 4 para el grupo, 0 para otros).

Fase 4: Restricción de Seguridad Perimetral en Directorios

Finalmente, la organización determinó una restricción crítica sobre el directorio `drafts` (borradores): exclusivamente el usuario administrador del proyecto (`researcher2`) debe tener privilegios de ejecución sobre esta carpeta. Ningún miembro del grupo ni usuarios externos deben contar con el permiso para ingresar a explorar o ejecutar las herramientas internas del directorio.

```
Consola de Seguridad de Directorios

researcher2@ubuntu:~/projects$ chmod g-x drafts
researcher2@ubuntu:~/projects$ ls -la
drwxr--r-x 2 researcher2 research 4096 May 20 18:30 drafts
```

Análisis del Impacto: Al ejecutar `chmod g-x drafts`, se eliminó de forma directa la capacidad del grupo para usar el comando `cd` dentro de la carpeta. Como la cuenta `researcher2` ya poseía permisos de ejecución nativos (representados en la primera tripleta `rxw`), no se requirieron modificaciones adicionales sobre el dueño.

Equivalencia Profesional Octal

Si la política corporativa además exigiera remover la lectura al grupo para blindar por completo la carpeta, la configuración recomendada a nivel numérico sería un estado restrictivo puro: **`chmod 700 drafts`** o un acceso estándar controlado de lectura únicamente: **`chmod 744 drafts`**.

5. Conclusión del Analista

A través de la ejecución de esta auditoría y la aplicación sistemática de los comandos de endurecimiento (*hardening*), se mitigaron proactivamente múltiples vectores de riesgo interno en los activos informáticos de la organización. La adopción consciente de metodologías de asignación de permisos, transitando del entendimiento visual de la cadena simbólica a la optimización de comandos por bloques numéricos (octales), permite establecer infraestructuras robustas y alineadas con las normativas globales de gobernanza de accesos de la industria de la ciberseguridad.